GLOBAL BUSINESS SOLUTIONS
FUTURE THINKING, NOW

GBS PROCESS FLOW

Artificial Intelligence — Organisational AI Compliance and Governance Process Flow

POPIA 4 of 2013 · EEA 55 of 1998 · LRA 66 of 1995 · National AI Policy (draft withdrawn April 2026; redraft pending) · ISO/IEC 42001:2023 · King V · EU AI Act where in scope · As at 19 October 2026

PREPARED FOR
[Client / Team]

PREPARED BY
Global Business Solutions

DATE
19 October 2026

VERSION
v1.0

DOCUMENT STATUS

Working document for legal review — not legal advice.

LAW = in force in SA; Code = Code of Good Practice (must be taken into account); CL = case law; POLICY/DRAFT = not binding; STD = standard; FOREIGN = foreign law where in scope; BP = best practice.

01 / AI COMPLIANCE PROCESS

Purpose, status and reading notes

This flow tells a South African organisation what to do, by when, and who hands off to whom, from the moment someone proposes to buy, build or switch on an artificial intelligence (AI) capability until that system is retired and the lessons feed back into policy. It covers predictive and classification models, generative AI (text, image, code and voice), AI agents that take actions on a user's behalf, and automated decision-making in HR and customer processes. It is written for two kinds of organisation at once: the **deployer**, which uses AI built by others (for example Microsoft 365 Copilot, a recruitment screening platform or a credit-scoring service), and the **developer or integrator**, which designs, configures or builds AI for itself or for clients (for example agents built in Voiceflow or Microsoft Copilot Studio). Where the two roles carry different duties, the flow says so; Phase 3 has a separate build track (3B).

Legal status. As at 19 October 2026 South Africa has **no AI-specific statute and no binding national AI policy**. Cabinet approved a Draft National Artificial Intelligence Policy for public comment on 25 March 2026 and it was published on 10 April 2026 (GN 3880, GG 54477), but the Minister of Communications and Digital Technologies withdrew it on 26 April 2026 after fictitious, apparently AI-generated citations were found in its reference list. An expert advisory panel chaired by Prof Benjamin Rosman was announced on 12 May 2026. The department told Parliament in May 2026 that it aimed to take a revised draft to Cabinet in November 2026 and publish it for comment in January 2027; in September 2026 the Minister moved the Cabinet target to the end of the 2026/27 financial year (March 2027), and no new comment date has been announced. Reporting in July 2026 indicates the redraft is likely to set national guidelines for sector strategies and to rely on existing regulators rather than create the seven new bodies the withdrawn draft proposed (not yet confirmed by the department). No AI Bill has been tabled. AI compliance in South Africa therefore flows from **technology-neutral laws**

already in force: chiefly the Protection of Personal Information Act 4 of 2013 (POPIA), the Employment Equity Act 55 of 1998 (EEA), the Labour Relations Act 66 of 1995 (LRA), the Consumer Protection Act 68 of 2008 (CPA), the Electronic Communications and Transactions Act 25 of 2002 (ECTA), the Cybercrimes Act 19 of 2020, the Copyright Act 98 of 1978, the Regulation of Interception of Communications and Provision of Communication-Related Information Act 70 of 2002 (RICA) and the Constitution. Standards and codes (ISO/IEC 42001, King V) and foreign law (the EU AI Act, where in scope) supply the management-system structure.

Figures and dates in force. POPIA administrative fine: up to R10 million (s.109). Amended POPIA Regulations in force from 17 April 2025. Information Regulator eServices portal mandatory for security-compromise notifications from 1 April 2025. King V Code: financial years starting on or after 1 January 2026. EU AI Act (Regulation (EU) 2024/1689) as amended by the Digital Omnibus on AI (Regulation (EU) 2026/1744, OJ 24 July 2026, in force 27 July 2026): prohibitions and AI literacy since 2 February 2025; general-purpose AI (GPAI) obligations since 2 August 2025; transparency duties (art. 50) since 2 August 2026; Annex III high-risk duties deferred to **2 December 2027**; Annex I (product) high-risk duties deferred to 2 August 2028.

Labels used throughout.

- **LAW** = binding in South Africa now (statute or regulation).
- **Code** = Code of Good Practice issued under a statute; must be taken into account (for example LRA s.203(3)).
- **CL** = case law (court judgments); binding to the extent of the court's authority.
- **POLICY / DRAFT** = government policy, draft policy or Bill; not binding. Build readiness; do not treat as a current legal duty.
- **STD** = voluntary standard or code (ISO/IEC, NIST, OECD, King V). Binding only if the organisation adopts it, a contract requires it, or a listing or sector rule incorporates it.
- **FOREIGN** = foreign law that applies only where the organisation is in its scope (for example the EU AI Act where an AI system's output is used in the EU).
- **BP** = best practice or internal control; not a statutory deadline. Adopt it as policy so it binds internally.

Design principle. Because no single statute governs AI in South Africa, the flow builds one gate-controlled life cycle and hangs every applicable legal test on the step where it bites. Where a stricter foreign or standard-based control is cheap to adopt and likely to become SA policy (risk tiering, impact assessment, human oversight, AI literacy, incident logging), the flow adopts it now as BP, so that the organisation will not need a redesign when the revised national policy or sector rules arrive.

Seven interpretation points that shape the flow.



1. Technology-neutral law still bites. POPIA, the EEA and the CPA apply to an outcome whether a person or a model produced it. "The tool did it" is not a defence: the responsible party (POPIA s.1) or employer (EEA s.5–6) answers for the result. Every AI use case must therefore be mapped to the human accountability it replaces.

2. "Based solely on automated processing" (POPIA s.71). The protection applies to a decision with legal consequences, or that affects the person to a substantial degree, which is based *solely* on automated processing intended to profile the person (performance at work, creditworthiness, reliability, location, health, personal preferences or conduct). The Information Regulator has issued no guidance on s.71 as at the date of this flow (verify before adoption). The flow treats a human "rubber stamp" that does not genuinely weigh the output as *not* human involvement, which is the cautious reading consistent with comparable foreign law. Meaningful review means a competent person with authority to differ, access to the inputs and time to consider them.

3. AI assessments of people are "similar assessments" under EEA s.8. Psychological testing "and other similar assessments" of an employee are prohibited unless the test is scientifically shown to be valid and reliable, can be applied fairly to all employees and is not biased against any employee or group. "Employee" includes an applicant (EEA s.9). The flow treats AI CV ranking, video-interview analysis, game-based assessment and personality inference as similar assessments. The HPCSA-certification paragraph (s.8(d)), inserted by the 2013 amendment, is not in operation: in *Association of Test Publishers of South Africa v President of the RSA* [2017] ZAGPPHC 144 (North Gauteng High Court, 3 May 2017) (CL) the court declared Proclamation 50 of 2014 void to the extent that it brought the amended s.8 into force, so s.8 as it stood on 31 July 2014 applies (no reported appeal found). The s.8(a)–(c) tests apply and the employer bears the burden of proof.

4. Deployer, developer and POPIA roles do not map one-to-one. An organisation using its own data in a vendor's AI is the responsible party and the vendor is normally an operator (POPIA s.20–21). A developer that builds an agent for a client and processes the client's data only on instructions is an operator. A vendor that uses customer data to train its own models for its own purposes becomes a responsible party in its own right for that processing, which needs its own lawful basis. Phase 1 step 1.2 settles the role before anything else.

5. EU AI Act reach. The EU AI Act applies to providers placing AI on the EU market and to providers and deployers outside the EU where the AI system's output is used in the EU (art. 2(1)(c)). A South African organisation with EU clients, EU employees or EU-facing chatbots must check scope at intake (step 1.5). Otherwise the Act is a reference model, not law.

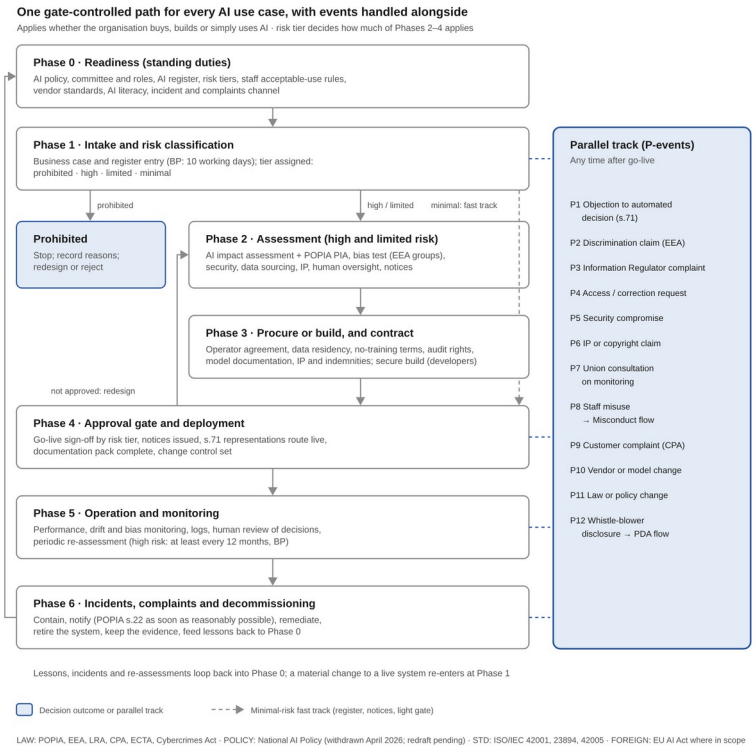
6. The four risk tiers are an internal policy device. "Prohibited, high, limited, minimal" mirrors the EU structure but is adapted to SA law (step 1.4). The tier decides how much assessment and which approver; it does not replace any statutory test.

7. Generative AI output is unverified until a person verifies it. South African courts have criticised practitioners for filing AI-generated fictitious authorities (*Parker v Forsyth NNO*, Johannesburg Regional Court, 29 June 2023; *Mavundla v MEC: Department of Co-operative Government and Traditional Affairs, KwaZulu-Natal* [2025] ZAKZPHC 2, 2025 (3) SA 534 (KZP), January 2025; *Northbound Processing (Pty) Ltd v South African Diamond and Precious Metals Regulator*, Gauteng Division, Johannesburg, case 2025-072038, 30 June 2025) (CL), and the withdrawal of the draft national AI policy shows the same risk at government level. POPIA s.16 (quality of information) also requires reasonably practicable steps to keep personal information accurate. The flow requires human verification of any AI output used externally, in a decision about a person, or in a legal, financial or safety document.

Roles used. AI Governance Owner (AIGO, accountable executive or senior manager who runs the programme); AI Governance Committee (AIC, cross-functional: AIGO, IO, HR, Legal, IT security, business; chaired by an executive); Board or Exco (BOARD, including the Social and Ethics or Risk Committee); Information Officer and Deputy Information Officers (IO); HR and Employment Equity Manager (HR); Legal and Compliance (LC); IT and Information Security (SEC); AI developers and builders (DEV, internal or contracted); Procurement (PROC); Business Owner of the use case (BO); line managers (LM); staff users (USER); designated PDA officer (DO, see the GBS PDA flow); affected persons (data subjects, candidates, customers).

02 / AI COMPLIANCE PROCESS

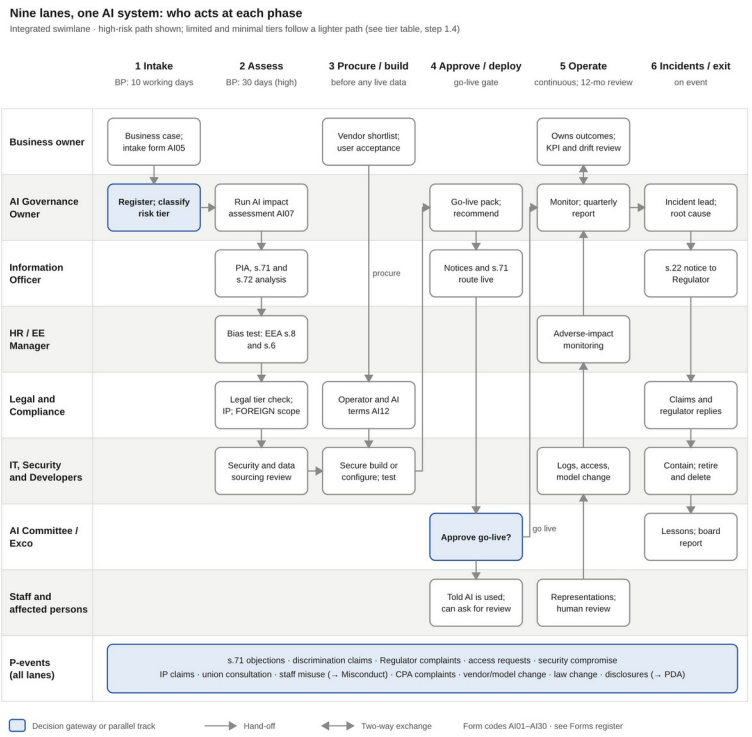
Master flow at a glance



Every AI use case enters at Phase 1, whether it is a new purchase, an in-house build, a client project or a new AI feature switched on inside software the organisation already licenses. The risk tier decides the path: a prohibited use stops; minimal-risk tools take a fast

track (register entry, notices, light sign-off); limited and high-risk uses go through full assessment, contracting and a formal go-live gate. Once live, the system is monitored until it is retired, and the parallel track handles events (objections, complaints, claims, compromises, misuse) whenever they arise. Lessons from every phase loop back into the Phase 0 controls, and any material change to a live system (new model, new data, new purpose) re-enters at Phase 1.

Integrated swimlane view



Read each phase column top to bottom to see who acts and who hands off; read each lane left to right to see one party's whole job across the life cycle. The AI Governance Owner lane is the spine: every other lane connects to it. The Information Officer and HR lanes carry the two heaviest legal tests (POPIA and the EEA). Affected persons appear at go-live (they must be told) and in operation (they can make representations and ask for human review). The P-events lane runs underneath from go-live until decommissioning.

03 / AI COMPLIANCE PROCESS

Phase 0 — Readiness (standing obligations)

Phase 0 has no case trigger. These controls must exist before the first use case is assessed, because every later step assumes a policy, an owner, a register and a scheme to classify against. Most organisations already use AI informally ("shadow AI"), so Phase 0 also includes discovering and registering what is already in use. For GBS and other builders, step 0.13 adds developer standards.

Step	Organisational action	Owner	Deadline	Form	Authority
0.1 Adopt the AI policy	Board-approved AI policy covering: scope (procure, build, use); principles (lawfulness, fairness, transparency, accountability, human oversight, security, privacy, safety); risk tiers and approval levels; prohibited uses; staff acceptable use; vendor and build standards; incident and complaints handling; review cycle. Link it to the POPIA, information security, EE, records and disciplinary policies rather than duplicating them.	BOARD, AIGO, LC	Now; review every 12 months and on any law or policy change (BP)	AI01	King V Principle 10 (STD); ISO/IEC 42001 cl. 5.2 (STD); POPIA s.8, s.19 (LAW)
0.2 Set governance structure and roles	Appoint the AIGO; constitute the AIC with written terms of reference, quorum and decision rights; confirm the IO and Deputy IOs are registered with the Information Regulator; name a business owner for each AI system. Define who may approve each tier (step 4.2). Report to the Board or Social and Ethics / Risk Committee at least quarterly.	BOARD	Now	AI02	King V Principle 10 (STD); ISO/IEC 42001 cl. 5.1, 5.3 (STD); POPIA s.55–56 (LAW)

Step	Organisational action	Owner	Deadline	Form	Authority
0.3 Build the AI register	Inventory every AI system and feature in use or in development: owner, purpose, vendor or builder, model and version, data categories (incl. special and children's PI), affected persons, decisions supported, hosting location, tier, assessment status, review date. Run a shadow-AI discovery (licence review, browser-extension and network logs within RICA s.6 limits, staff survey). Include AI features activated inside existing SaaS.	AIGO, SEC	Now; then live	AI03	ISO/IEC 42001 Annex A.4–A.5 (STD); POPIA s.17 records of processing (LAW)
0.4 Adopt the risk classification scheme	Approve the four-tier scheme and criteria in step 1.4, with SA-specific triggers (s.71 decisions, EEA s.8 assessments, special PI, children, safety-critical, customer eligibility). State what each tier requires and who approves.	AIC, LC	Now	AI04	ISO/IEC 23894 (STD); NIST AI RMF "Map" (STD); EU AI Act art. 5–6 as reference (FOREIGN)
0.5 Set staff acceptable-use rules (incl. generative AI)	Publish an approved-tools list; prohibit entering personal information, client confidential information, credentials or source code into unapproved public tools; require verification of facts, figures, citations and code before use; require disclosure where AI materially drafted external content; ban deepfakes of real people, covert recording and any prohibited use; explain monitoring. Staff acknowledge in writing. Breach is a disciplinary matter (Misconduct flow).	AIGO, HR, LC	Now; acknowledgement at induction and annually (BP)	AI06	POPIA s.19 (LAW); Code of Good Practice: Dismissal, 2025 (rules must be known) (Code); Cybercrimes Act s.16 (LAW)
0.6 Set vendor and contract standards	Standard AI due-diligence questionnaire and AI contract schedule (operator terms, no training on organisation data without approval, data residency, model-change notice, audit, incident notice, IP indemnity, exit). Procurement may not sign AI purchases or enable AI features without AIGO clearance.	PROC, LC, SEC	Now	AI11, AI12	POPIA s.20–21, s.72 (LAW); ISO/IEC 42001 Annex A.10 (STD)
0.7 AI literacy and training	Tiered training: all staff (acceptable use, verification, privacy); users of high-risk systems (limits, oversight duties, how to override); AIC and approvers (assessment); developers (secure and responsible build). Record attendance. Training can be recorded in the Workplace Skills Plan.	HR, AIGO	Now; annually (BP)	AI26	EU AI Act art. 4 as amended by Reg 2026/1744 (FOREIGN, in force 27 July 2026); ISO/IEC 42001 cl. 7.2–7.3 (STD)

Step	Organisational action	Owner	Deadline	Form	Authority
0.8 Open the incident and complaints channel	One route for staff, candidates and customers to report AI errors, harm, bias, misuse or a security event and to ask for human review; triage within 2 working days (BP). Link to the POPIA breach procedure and the PDA whistle-blowing channel.	AIGO, IO	Now	AI23, AI24	POPIA s.22, s.74 (LAW); PDA (LAW); ISO/IEC 42001 cl. 10.2 (STD)
0.9 Logging and records standard	Define what each tier must log (inputs, outputs, model version, prompts or system instructions, human reviewer and decision, overrides), who can access logs, and retention (minimum needed for the purpose plus any dispute period; POPIA s.14).	SEC, IO	Now	AI03, AI21	POPIA s.14, s.19 (LAW); ISO/IEC 42001 Annex A.6.2.8 (STD)
0.10 Legal and regulatory watch	Monitor: revised National AI Policy (Cabinet target moved to March 2027; comment date not yet announced); Information Regulator guidance (PIIA guidance note planned 2026/27); Copyright Amendment Bill; sector regulators (FSCA, PA, HPCSA); EU AI Act milestones. Log each change and its impact.	LC	Monthly (BP)	AI29	BP
0.11 Align POPIA baseline	Confirm the POPIA programme covers AI: PAIA manual lists AI processing purposes and recipients; privacy notices mention automated decisions and profiling; the PIA method (POPIA Regulations reg. 4) includes AI questions; operator register includes AI vendors. See the GBS POPIA Compliance flow.	IO	Now	AI07 (template)	POPIA s.17–18, s.71; Regulations reg. 4 (LAW); PAIA s.51 (LAW)
0.12 Engage the workforce	Consult the workplace forum where one exists (s.84(1): new technology and work methods) and engage recognised unions as collective agreements require, disclosing relevant information under s.16, on the AI policy, workplace monitoring and the introduction of AI that changes work methods. If dismissals are possible, s.189 applies (Operational Requirements flow). Record agreements.	HR, LM	Before first high-risk workplace deployment	AI27	LRA s.16, s.84(1) (LAW); RICA s.6 (LAW); EU AI Act art. 26(7) (FOREIGN, from 2 December 2027)

Step	Organisational action	Owner	Deadline	Form	Authority
0.13 Developer standards (builders only)	Secure and responsible build standard: approved platforms and model providers; environment separation; system-prompt and knowledge-source change control; least-privilege connectors and tool permissions for agents; evaluation suites (accuracy, hallucination, bias, red-team, prompt injection); documentation (system card); client hand-over pack and role allocation.	DEV, SEC, AIGO	Now	AI10, AI17	POPIA s.19, s.21 (LAW); ISO/IEC 42001 Annex A.6 (STD); OWASP Top 10 for LLM Applications (STD); NIST AI 600-1 (STD)

Staff obligations at this stage. Read and acknowledge the acceptable-use rules; use only approved tools; complete AI literacy training; declare AI tools already in use when the register is built.

Hand-offs. BOARD → AIGO (mandate and policy). AIGO → HR (training and acknowledgements). AIGO → PROC (no AI purchase without clearance). IO → AIGO (POPIA baseline). HR → union or forum (consultation).

Watch. The biggest Phase 0 failure is an AI policy that ignores AI already switched on. Enterprise copilots inherit every permission a user has: if SharePoint or Teams sites are over-shared, the copilot will surface salary files, disciplinary records or client data to anyone who asks. Fix permissions and sensitivity labels before enabling a tenant-wide copilot.

04 / AI COMPLIANCE PROCESS

Phase 1 — Intake and risk classification

Phase 1 turns an idea into a registered, classified use case with a named owner and an assessment plan. It applies to new purchases, in-house builds, client projects, pilots and proofs of concept that touch real data, and to new AI features released by an existing vendor.

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
1.1 Receive the request	Proposal to buy, build, pilot or enable AI; vendor notice of a new AI feature; client request (builders)	Business owner submits the intake form: problem, intended purpose, users, affected persons, data, decisions supported, autonomy level (assist, recommend, decide, act), vendor or build, benefits and success measures, alternatives considered. AIGO logs it in the register with status "intake".	BO, AIGO	Log on receipt; complete intake within 10 working days (BP)	AI05, AI03	ISO/IEC 42001 Annex A.5, A.9 (STD)
1.2 Settle the roles	Intake logged	Record whether the organisation is deployer, developer/provider, integrator, or more than one. Map POPIA roles: responsible party, operator, joint responsible parties. Where the vendor wants to train on the organisation's data, record that the vendor becomes a responsible party for that processing.	LC, IO	With 1.1	AI05	POPIA s.1, s.20–21 (LAW)
1.3 Screen for prohibited uses	Intake logged	Apply the prohibited list in the tier table. If any item applies, stop, record reasons and tell the business owner; redesign is allowed.	AIGO, LC	Within 5 working days (BP)	AI04	Internal policy; EEA s.6, s.8; POPIA s.26; RICA; Cybercrimes Act; EU AI Act art. 5 (FOREIGN, where in scope)
1.4 Assign the risk tier	Not prohibited	Classify as high, limited or minimal using the tier table and the SA triggers. Where two tiers could apply, take the higher. Record reasoning.	AIGO	Within 10 working days of 1.1 (BP)	AI04, AI03	ISO/IEC 23894 (STD); internal policy
1.5 Check foreign-law scope	Tier assigned	Check whether output is used in the EU, the system is offered to EU users, or EU employees are affected; whether any other foreign AI or privacy law applies (for example where a client is regulated abroad). If in scope, add the foreign requirements to the assessment plan, with dates.	LC	With 1.4	AI05	EU AI Act art. 2(1) (FOREIGN)

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
1.6 Check sector rules	Tier assigned	Financial services: FSCA and PA expectations, Joint Standards on IT governance and cybersecurity, Treating Customers Fairly. Health: HPCSA and health data rules. Mining and safety-critical: Mine Health and Safety Act duties where AI is a safety component. Record each rule.	LC	With 1.4	AI05	Joint Standard 1 of 2023 (IT governance, from 15 November 2024) and Joint Standard 2 of 2024 (cybersecurity, from 1 June 2025) (LAW, sector); PA/FSCA report on AI, 24 November 2025 (POLICY)
1.7 Set the assessment plan	Tier and scope settled	High: full AI impact assessment (Phase 2) with all modules; limited: AIIA-lite (privacy, transparency, security, IP, plus special PI (2.3) and cross-border transfer (2.8) whenever triggered); minimal: register entry and acceptable-use check only, then step 4.2 fast track. Name the assessors and target dates.	AIGO	Within 10 working days of 1.1 (BP)	AI05	ISO/IEC 42005:2025 (STD)
1.8 Notify the committee	High-risk or novel use	AIGO tables the use case at the next AIC meeting, or by round-robin if urgent, so that members can flag concerns early.	AIGO	Next AIC meeting (BP)	AI02 minutes	King V Principle 10 (STD)

Risk tier table (adopted as internal policy)

Tier	Typical South African examples	What the tier requires
Prohibited	Emotion recognition of employees or candidates (except medical or safety); social scoring of staff or customers; biometric categorisation that infers race, religion, sexual orientation, union membership or political views; manipulative or exploitative techniques aimed at vulnerable people; covert interception of staff communications outside RICA s.6; untargeted scraping of facial images; fully automated dismissal or disciplinary decisions; deepfakes or intimate images of real people without consent; special or confidential information in unapproved public tools.	Stop. Record reasons. Redesign only.
High	Recruitment and selection (CV screening, ranking, video or game-based assessment, personality inference); promotion, performance rating, task allocation by behaviour, termination support; workplace monitoring analytics; credit, insurance, eligibility or pricing decisions about individuals; health or wellness inferences; biometric identification; AI as a safety component (mining, plant, vehicles); agents that act without human approval (payments, external messages, record changes); large-scale processing of special or children's PI; any decision within POPIA s.71.	Full AIIA and PIA; bias test; security review; human-oversight design; transparency notices; s.71 route; AIC approval; monitoring plan; re-assessment at least every 12 months (BP).
Limited	Chatbots and voice agents that interact with people; generative content published externally; internal copilots with access to personal information; summarisation of HR, client or employee documents; agents that draft but a person sends.	AIIA-lite (incl. 2.3 and 2.8 where triggered); AI-interaction disclosure; content labelling where relevant; permissions review; AIGO and IO approval; 24-month review (BP).
Minimal	Spell and grammar check, spam filtering, translation of public text, code completion on non-sensitive code, drafting with no personal or confidential data.	Register entry; acceptable-use rules; business owner and AIGO sign-off.

Business owner obligations at this stage. Describe the use case honestly, including the autonomy level and every data source; do not start a pilot on live personal data before the tier is assigned.



Hand-offs. BO → AIGO (intake). AIGO → LC (roles, foreign and sector scope). AIGO → AIC (high risk). AIGO → BO (prohibited outcome with reasons).

Watch. Under-classification is the usual failure: "it only recommends" is often untrue in practice when managers accept the ranking without looking. Classify on how the tool will actually be used, and revisit the tier if usage drifts towards automated decisions.

05 / AI COMPLIANCE PROCESS

Phase 2 — Assessment

Phase 2 is one combined assessment, the AI impact assessment (AIIA), which includes the POPIA personal information impact assessment so that the business sees a single document and a single residual-risk decision. High-risk use cases complete every module; limited-risk use cases complete modules 2.2, 2.4, 2.7, 2.9 and 2.11 (AIIA-lite), plus 2.3 and 2.8 whenever special or children's PI is involved or personal information leaves South Africa, because those are statutory tests that apply at every tier. The assessment is done on the system as it will actually be configured and used, not on the vendor's brochure.

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
2.1 Scope the assessment	Assessment plan approved (1.7)	Assemble the team (AIGO lead; IO; HR for people decisions; LC; SEC; DEV or vendor). Collect the vendor documentation, model or system card, data-flow diagram and intended configuration.	AIGO	Start within 5 working days of 1.7 (BP)	AI07	ISO/IEC 42005:2025 (STD); POPIA Regulations reg. 4(1)(b) (LAW)
2.2 Purpose, lawful basis and minimality	Scope set	Record the specific purpose; the lawful basis for each processing activity (consent, contract, legal obligation, legitimate interest); necessity and proportionality; whether less intrusive means would do; that only adequate, relevant, non-excessive data is used; and whether any further processing (for example reusing HR data to train a model) is compatible with the original purpose.	IO	Within the 30-day assessment window (BP)	AI07	POPIA s.9–11, s.13, s.15 (LAW)

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
2.3 Special and children's PI	Data mapped	Identify special PI (race, ethnic origin, health, biometrics, religion, trade union membership, sex life, political persuasion, criminal behaviour) and children's PI, whether processed directly or *inferred* by the model. Confirm a general authorisation (s.27) or specific authorisation (s.28–33), or exclude the data. Check whether prior authorisation from the Regulator is needed (s.57).	IO, LC	As 2.2	AI07	POPIA s.26–35, s.57–58 (LAW)
2.4 Automated decision test (s.71)	Decision about a person is supported	Ask: is there a decision; does it have legal consequences or substantially affect the person; is it based solely on automated processing; does it profile the person? If yes, either redesign so that a competent person makes the decision, or rely on an exception (contract with appropriate measures, or law or code of conduct) and build the s.71(3) measures: an opportunity to make representations and sufficient information about the underlying logic.	IO, LC	As 2.2	AI07, AI16	POPIA s.5(g), s.71 (LAW)
2.5 Bias and fairness testing	People are scored, ranked or selected	Define protected groups (EEA designated groups: black people, women, people with disabilities; and all s.6(1) grounds). Test outcomes by group on representative SA data: selection rates, error rates, adverse-impact ratio (four-fifths rule as a screening indicator only, BP). Check proxies (postal code, home language, school, name, gaps in employment, voice and accent). For assessments, obtain validity and reliability evidence for the SA population. Record mitigations. Race data used for testing must be held under s.27 and s.29 and kept separate.	HR, AIGO, DEV or vendor	Before procurement sign-off for high risk (BP)	AI08	EEA s.5, s.6, s.8, s.11 (LAW); PEPUDA s.6–7 for customers (LAW); CPA s.8–10 (LAW)
2.6 Data sourcing and training data	Training, fine-tuning or retrieval data used	Record the source, lawful collection, consent or other basis, licence terms, scraping restrictions, accuracy and representativeness of every dataset and knowledge source. For retrieval (RAG) agents, record which document libraries the agent can search and confirm their permissions.	DEV, IO	As 2.5	AI09	POPIA s.12, s.16 (LAW); Copyright Act s.6–7 (LAW)

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
2.7 Security and threat assessment	All high and limited	Assess AI-specific threats: prompt injection (direct and via documents or web pages), data leakage through outputs, over-permissioned connectors, model or output manipulation, insecure plug-ins, training-data poisoning, model inversion, credential exposure, denial of wallet. Map to controls. Confirm the vendor's certifications and penetration testing.	SEC, DEV	As 2.5	AI10	POPIA s.19 (LAW); Cybercrimes Act s.2–6 (LAW); OWASP Top 10 for LLM Applications (STD); ISO/IEC 27001 (STD)
2.8 Cross-border transfer	Data leaves South Africa (hosting, processing, support access, model API)	Identify every country; apply s.72 (adequate law, binding corporate rules or agreement; consent; contract necessity; benefit). If special or children's PI goes to a country without adequate protection, check s.57(1)(d) prior authorisation.	IO, LC	As 2.5	AI28	POPIA s.72, s.57(1)(d) (LAW)
2.9 IP and copyright	All high and limited	Check: rights in training and retrieval data; licence terms for model outputs; who owns outputs (Copyright Act s.1 deems the author of a computer-generated work to be the person who made the necessary arrangements, which matters for client deliverables); risk of outputs reproducing third-party works; confidentiality of prompts and outputs; open-source licence obligations in generated code.	LC	As 2.5	AI13	Copyright Act 98 of 1978 s.1, s.21, s.23 (LAW); Copyright Amendment Bill (DRAFT; ConCourt [2026] ZACC 26: no TDM or AI-training exception)
2.10 Human oversight design	All high; limited where it acts	Decide the autonomy level and who oversees: competence, authority to override, information shown (score, reasons, confidence, inputs), time allowed, escalation, and a stop or fallback route. For agents: which actions need human approval before execution; spending and messaging limits; kill switch.	BO, AIGO, DEV	As 2.5	AI14	POPIA s.71 (LAW); King V Principle 10 (STD); ISO/IEC 42001 Annex A.9 (STD)
2.11 Transparency notices	All high and limited	Draft the notices: AI-interaction disclosure for chatbots and voice agents; notice to candidates and employees that AI is used, for what and how to ask for human review; customer notice of automated decisions; labelling of synthetic content. Notices must be in plain language.	IO, LC, HR	As 2.5	AI15	POPIA s.18 (LAW); CPA s.22, s.41 (LAW); EU AI Act art. 50 (FOREIGN, from 2 August 2026)

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
2.12 Workforce impact	Jobs, work methods or monitoring change	Assess effects on roles, skills, workload and monitoring; plan consultation (0.12). If redundancies are possible, hand off to the Operational Requirements flow before any decision is made.	HR, LM	Before procurement sign-off (BP)	AI27	LRA s.16, s.84, s.189 (LAW)
2.13 Residual risk and recommendation	Modules complete	Score residual risk after mitigations; recommend proceed, proceed with conditions, redesign or reject; list conditions that must be met before go-live. The IO signs the privacy part; HR signs the bias part.	AIGO	Day 30 for high (BP)	AI07	ISO/IEC 23894 (STD); POPIA Regulations reg. 4 (LAW)

Business owner obligations at this stage. Make the real configuration and data available; accept that a "proceed with conditions" outcome binds the project budget and timeline.

Hand-offs. AIGO → IO (privacy modules). AIGO → HR (bias and EEA modules). AIGO → SEC (threat model). AIGO → LC (IP, foreign scope). HR → Operational Requirements flow (possible redundancies). AIGO → PROC or DEV (conditions to carry into Phase 3).

Watch. Vendors often refuse to share bias-test results or say their model is "unbiased". EEA s.11 places the burden on the employer, not the vendor: if the vendor will not support testing on South African data, treat that as a reason not to use the tool for hiring or promotion.

Phase 3 — Procure or build, and contract

Phase 3 converts the assessment conditions into contract terms (3A, procurement) or build controls (3B, in-house or client build). Both tracks run before any live personal data enters the system; pilots use synthetic, anonymised or minimal data unless the AIGO approves otherwise in writing.

Track 3A — Procurement and contracting

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
3A.1 Vendor due diligence	Proceed or proceed with conditions	Issue the AI questionnaire: model provenance and versioning; training-data sources and opt-outs; whether customer data trains the model; hosting regions and sub-processors; security certifications; bias testing and SA validation; explainability features; logging; incident history; insurance; EU AI Act role and compliance where relevant. Score the answers.	PROC, SEC	Before contract (BP: 15 working days)	AI11	POPIA s.19(1), s.21 (LAW); ISO/IEC 42001 Annex A.10 (STD)
3A.2 Operator agreement	Vendor processes PI	Written operator agreement: process only on instructions; confidentiality; security measures; notify the responsible party immediately of any reasonable belief of unauthorised access; return or destroy data on exit; sub-processor control.	LC, IO	Signed before live data	AI12	POPIA s.20, s.21, s.22(1) (LAW)
3A.3 AI-specific terms	All AI contracts	AI schedule: no training or fine-tuning on organisation data without written approval; data residency and transfer conditions; retention limits for prompts and outputs; advance notice of model or material feature changes; documentation and transparency deliverables; support for bias testing and audit; incident notice within a fixed number of hours (BP: 24–72); service levels for accuracy where measurable; IP indemnity for outputs and training data; liability that is not capped below realistic exposure; exit assistance and data return.	LC, PROC	Signed before live data	AI12	POPIA s.21, s.72 (LAW); CPA s.48 (only where the organisation is itself a consumer, i.e. a juristic person below R2 million asset value and turnover) (LAW)
3A.4 Cross-border mechanism	Data leaves SA	Put in place the s.72 mechanism identified in 2.8 (agreement clauses, BCRs, consent) and record it.	IO, LC	Before live data	AI28	POPIA s.72 (LAW)
3A.5 Click-through and free tools	Tool offered on standard terms only	Review the standard terms against AI12. If the terms allow training on inputs or have no operator undertakings, restrict use to non-personal, non-confidential data or reject.	LC, AIGO	Before enablement	AI12	POPIA s.21 (LAW)



Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
3A.6 Pilot	Contract signed	Run a time-boxed pilot in a controlled environment, with the evaluation measures from the AIIA; record results.	BO, SEC	As planned	AI20	BP

Track 3B — Build, configure and integrate (developers and integrators)

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
3B.1 Design specification	Proceed decision	Specify purpose, scope boundaries, refusal behaviour, system instructions, knowledge sources, connectors and tools, autonomy limits and human-approval points, logging and data retention. Version-control the system instructions.	DEV, BO	Before build (BP)	AI17	ISO/IEC 42001 Annex A.6.2 (STD)
3B.2 Data pipeline	Specification approved	Connect only approved sources; apply least-privilege service accounts; mask or exclude special PI not needed; set retention for conversation logs; keep development and production data separate.	DEV, SEC	During build	AI09	POPIA s.10, s.14, s.19 (LAW)
3B.3 Evaluation and red-teaming	Working build	Run the evaluation suite: task accuracy on representative cases; hallucination and citation checks; bias tests (2.5); refusal of out-of-scope and harmful requests; prompt-injection and data-exfiltration attempts; agent action limits; accessibility and language coverage (for example isiZulu, isiXhosa, Afrikaans where users need them). Fix and retest.	DEV, SEC	Before go-live pack	AI08, AI10	POPIA s.16, s.19 (LAW); NIST AI 600-1 (STD); OWASP LLM Top 10 (STD)
3B.4 Documentation	Evaluation passed	System card: purpose, limits, data, model and version, evaluation results, known failure modes, oversight instructions, change log.	DEV	Before go-live pack	AI17	ISO/IEC 42001 Annex A.6.2.7 (STD)

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
3B.5 Client role allocation (building for clients)	Client project	Contract records that the builder is an operator for client data; who is responsible for notices, s.71 routes, bias testing on the client's population, monitoring and incident notification; IP ownership in configuration, prompts and outputs; hand-over pack (system card, admin guide, monitoring checklist).	DEV, LC	Before client go-live	AI12, AI17	POPIA s.20–21 (LAW); Copyright Act s.1, s.21 (LAW)
3B.6 Platform terms check	Third-party build platform or model API	Confirm the platform's data-use, hosting and retention settings (for example disabling training on inputs, choosing the hosting region, setting log retention) match AI12 and the client contract.	DEV, SEC	Before live data	AI12	POPIA s.21, s.72 (LAW)

Vendor and developer obligations at this stage. Answer due-diligence questions truthfully; disclose sub-processors and training practices; notify model changes; deliver documentation; support testing and audit.

Hand-offs. PROC → LC (contract). LC → IO (operator and transfer terms). DEV → SEC (security tests). DEV → AIGO (system card and evaluation results). BO → AIGO (pilot results).

Watch. A contract signed before the assessment is finished loses the leverage to secure no-training, audit and model-change terms. Make AIGO clearance a condition of the purchase order, and treat AI features in renewals as a new procurement.

07 / AI COMPLIANCE PROCESS

Phase 4 — Approval gate and deployment

Phase 4 is the single go/no-go decision. Nothing reaches live personal data or real decisions without a signed go-live certificate at the right level. The gate checks that every condition from Phase 2 is met, that notices and the s.71 route are live, and that someone owns monitoring from day one.

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
4.1 Compile the go-live pack	Phase 3 complete	Assemble: AIIA and conditions tracker; bias and evaluation results; security sign-off; contracts; notices; oversight design; monitoring plan; training records; system card; rollback plan.	AIGO	5 working days before the target date (BP)	AI18	ISO/IEC 42001 cl. 8 (STD)
4.2 Approval decision	Pack complete	Minimal: BO and AIGO. Limited: AIGO and IO. High: AIC (IO and HR must concur for people decisions). Decide approve, approve with conditions, defer or reject; record reasons. Rejected or deferred cases return to Phase 2 or 3 for redesign.	AIC, AIGO	At the gate meeting	AI18	King V Principle 10 (STD)
4.3 Issue notices	Approved	Publish or send the notices (AI15): privacy notice update; candidate and employee notices; chatbot disclosure at the start of each interaction; content labels. Update the PAIA manual if purposes or recipients changed.	IO, HR	Before first live use	AI15	POPIA s.18 (LAW); PAIA s.51 (LAW)
4.4 Activate the s.71 route	s.71 decision in scope	Publish how affected persons make representations and obtain human review; train reviewers; set response targets (BP: acknowledge in 2 working days, decide in 10). Provide sufficient information about the underlying logic so that the person can make representations (in the decision notice, with more detail on request).	IO, BO	Before first live decision	AI16	POPIA s.71(3) (LAW)
4.5 Train users and overseers	Approved	Train users on purpose, limits, verification and override; train overseers on the oversight design; record attendance.	HR, BO	Before access is granted	AI26	ISO/IEC 42001 cl. 7.2 (STD); EU AI Act art. 4, 26(2) (FOREIGN)
4.6 Baseline and register	Approved	Record the approved version (model, system instructions, knowledge sources, configuration) as the baseline; update the register status to "live"; set review dates.	AIGO, DEV	On go-live	AI03, AI19	ISO/IEC 42001 Annex A.6.2.6 (STD)
4.7 Controlled roll-out	Approved	Phased roll-out with heightened monitoring (hypercare) for the first 30 days (BP); rollback trigger defined; daily issue log.	BO, SEC	30 days (BP)	AI20	BP

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
4.8 Change control	Any change after go-live	Any change to model or version, system instructions, data sources, purpose, users, autonomy level or hosting goes through change control; a material change re-enters Phase 1.	AIGO, DEV	Before the change (BP)	AI19	ISO/IEC 42001 cl. 6.3 (STD)

Affected persons at this stage. They have a right to be told their information is processed and for what purpose (POPIA s.18), not to be subject to a solely automated decision except as s.71 allows (s.5(g)), and to object on reasonable grounds to processing based on legitimate interests (s.11(3)).

Hand-offs. AIGO → AIC (go-live pack). AIC → AIGO (certificate and conditions). IO → affected persons (notices). HR → candidates and employees (notices, review route). AIGO → BO (monitoring ownership).

Watch. Notices that say "we may use AI" are not enough. Tell people what the AI does in their case, whether a person decides, and exactly how to ask for human review. If a candidate cannot find the review route, the s.71 safeguard does not exist in practice.

Phase 5 — Operation and monitoring

Phase 5 runs for as long as the system is live. AI systems change after go-live even when nobody touches them: vendors update models, input data drifts, users find new uses, and staff stop checking outputs once they trust them. Monitoring therefore covers the system, its outcomes and its users.

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
5.1 Performance monitoring	Go-live	Track the success measures and error rates set in the AIIA; sample outputs for accuracy and hallucination; track complaints and overrides; compare with the go-live baseline.	BO	Monthly for high, quarterly for limited (BP)	AI20	POPIA s.16 (LAW); ISO/IEC 42001 cl. 9.1 (STD)



Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
5.2 Bias and adverse-impact monitoring	People decisions	Repeat the group outcome analysis on live data; investigate any adverse-impact ratio below 0.8 or a significant error-rate gap; check that EE reporting data and AI outcome data tell the same story.	HR	Quarterly (BP) and before EEA reporting	AI08, AI20	EEA s.5, s.6, s.8 (LAW)
5.3 Human review and override log	Oversight design in force	Record each human review, override and reason; watch for automation bias (near-100% acceptance) and for reviewers without time or information to review.	BO, LM	Continuous	AI21	POPIA s.71 (LAW)
5.4 Logs and access reviews	Go-live	Keep logs to the 0.9 standard; review who has access to the system, its logs and its connectors; remove leavers (Off-Boarding flow).	SEC	Quarterly (BP)	AI03	POPIA s.14, s.19 (LAW)
5.5 Vendor and model changes	Vendor notice or detected change	Assess the change; re-run evaluations on a material change; decide whether to accept, delay or roll back; update the baseline.	AIGO, DEV	Before the change takes effect where possible (BP)	AI19	ISO/IEC 42001 cl. 8.1 (STD)
5.6 Staff usage monitoring	Acceptable-use rules in force	Monitor use of approved and unapproved AI tools within RICA s.6 and the communicated monitoring policy; follow up shadow AI by registering or blocking the tool; handle misuse through the Misconduct flow (P8).	SEC, HR	Monthly (BP)	AI03	RICA s.6 (LAW); LRA (LAW)
5.7 Periodic re-assessment	Review date or trigger	Re-run the AIIA: high every 12 months, limited every 24 months (BP), or sooner on a material change, incident, complaint trend or law change. Confirm the tier still fits.	AIGO	As scheduled	AI22	ISO/IEC 42001 cl. 9.3 (STD); POPIA Regulations reg. 4 (LAW)
5.8 Governance reporting	Quarter end	Report to the AIC and Board: register summary, new and retired systems, incidents, complaints, s.71 requests, bias results, overdue reviews, regulatory watch. Disclose AI governance in the King V disclosure where applicable.	AIGO	Quarterly (BP)	AI30	King V Principle 10 (STD)
5.9 Internal audit	Annual plan	Independent check of the AI management system (register completeness, assessments, approvals, monitoring evidence). Optional external certification against ISO/IEC 42001.	Internal audit	Annually (BP)	AI30	ISO/IEC 42001 cl. 9.2 (STD); ISO/IEC 42006:2025 (STD)

User obligations at this stage. Use the system only for its approved purpose; verify outputs before relying on them; record overrides; report errors, bias or strange behaviour through the channel.

Hand-offs. BO → AIGO (monthly metrics). HR → AIGO (bias results). SEC → HR (misuse evidence). AIGO → AIC and Board (quarterly report). Vendor → AIGO (change notices).

Watch. A falling override rate is not proof that the system got better. It is often a sign that reviewers stopped reviewing. Sample decisions where the human agreed with the system and check whether the reviewer looked at the evidence.

09 / AI COMPLIANCE PROCESS

Phase 6 — Incidents, complaints and decommissioning

Phase 6 handles anything that goes wrong and the orderly retirement of a system. An AI incident includes a security compromise, a harmful or discriminatory output, a wrong automated decision, a hallucinated statement given to a customer, an agent that acted outside its limits, or a confidential-data leak through a prompt.

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
6.1 Log and triage	Report through any channel or monitoring alert	Log in the incident register; classify severity (personal information involved, people affected, decisions affected, external exposure, safety); appoint an incident lead.	AIGO	Same day (BP)	AI23	ISO/IEC 42001 cl. 10.2 (STD)
6.2 Contain	Severity medium or higher	Pause the feature, disable the connector or revert to manual processing; preserve logs and the current configuration as evidence; stop further decisions until reviewed.	SEC, BO	Immediately (BP)	AI23	POPIA s.19 (LAW)

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
6.3 Security compromise notification	Reasonable grounds to believe PI was accessed or acquired by an unauthorised person	Notify the Information Regulator (eServices portal) and affected data subjects as soon as reasonably possible after discovery, with the details s.22(5) requires; operators must notify the responsible party immediately. See the GBS POPIA Compliance flow.	IO	As soon as reasonably possible (LAW); internal target 72 hours (BP)	AI23	POPIA s.21(2), s.22 (LAW)
6.4 Cybercrime reporting	Offence under the Cybercrimes Act suspected	Preserve evidence; consider a SAPS report. Electronic communications service providers and financial institutions must check whether the s.54 reporting duty has commenced (verify).	SEC, LC	Without delay (BP)	AI23	Cybercrimes Act s.2–10, s.54 (LAW)
6.5 Correct affected decisions	Wrong or biased decisions identified	Identify affected people; re-decide with human review; correct records (POPIA s.24); tell the people affected what happened and what was done.	BO, IO, HR	Within 30 days (BP)	AI23	POPIA s.16, s.24 (LAW); EEA s.6 (LAW)
6.6 Root cause and fix	Contained	Root-cause analysis (data, model, configuration, oversight, user behaviour, vendor); corrective actions; re-test before restart; re-assessment if the tier or design changes.	AIGO, DEV	Within 30 days (BP)	AI23, AI22	ISO/IEC 42001 cl. 10.2 (STD)
6.7 Complaints	Complaint from a person or customer	Log; acknowledge within 2 working days; investigate with human review; respond in writing with reasons within 20 working days (BP); tell the complainant about the Information Regulator, CCMA or consumer routes as relevant.	AIGO, BO	2 and 20 working days (BP)	AI24	POPIA s.74 (LAW); CPA s.69 (LAW)
6.8 Decision to decommission	End of need, unfixable risk, vendor exit, contract end	AIC approves retirement and the replacement or manual process; communicate to users and affected persons.	AIC, BO	Before contract end (BP)	AI25	ISO/IEC 42001 Annex A.6.2.6 (STD)
6.9 Data return and deletion	Retirement approved	Obtain return or certified destruction of data, logs, fine-tuned models and embeddings held by the vendor; delete or de-identify internal copies not needed for records; revoke credentials and connectors.	SEC, IO	Within 30 days of retirement (BP)	AI25	POPIA s.14, s.21 (LAW)

Step	Trigger	Organisational action	Owner	Deadline	Form	Authority
6.10 Archive the evidence	Retirement	Keep the AIIA, approvals, system card, monitoring and incident records for the dispute period (at least the longest referral or prescription period that could apply; BP 3–5 years).	AIGO	On retirement	AI25	POPIA s.14(1)(a)–(b) (LAW); Prescription Act 68 of 1969 (LAW)
6.11 Lessons into Phase 0	Incident closed or system retired	Update policy, tier scheme, vendor standards, training and the register.	AIGO	Next AIC meeting (BP)	AI30	ISO/IEC 42001 cl. 10.1 (STD)

Affected persons at this stage. They may complain to the organisation and to the Information Regulator, refer an unfair discrimination dispute to the CCMA, or approach a court for damages under POPIA s.99.

Hand-offs. AIGO → IO (possible compromise). IO → Information Regulator and data subjects (s.22). SEC → SAPS (cybercrime). HR → affected employees and candidates (corrected decisions). AIGO → AIC (root cause, decommissioning).

Watch. Do not delete the system or its logs in a hurry after an incident. The evidence is needed to correct decisions, answer the Regulator and defend claims. Contain first, preserve second, delete only when the matter is closed.

Parallel track — events during operation

These events can occur at any time after go-live (and some during a pilot). Each is handled on its own clock while the system continues or is paused.

Event	Who	Trigger	Organisational action	Deadline	Form	Authority
P1 Objection to an automated decision	IO, BO	Data subject asks for human review or objects to a decision	Acknowledge; suspend reliance on the automated output for that person; competent reviewer re-decides with full information; explain the underlying logic in plain language; record outcome.	Acknowledge 2, decide 10 working days (BP)	AI16, AI21	POPIA s.5(g), s.11(3), s.71(3) (LAW)
P2 Discrimination claim	HR, LC	Candidate or employee alleges unfair discrimination by an AI-assisted process	Preserve the AIIA, bias tests, logs and decision records; assess validity evidence; respond to the CCMA referral; consider suspending the tool. On a listed ground the employer must prove, on a balance of probabilities, that the discrimination did not take place, or is rational and not unfair, or is otherwise justifiable (s.11(1)); on an arbitrary ground the complainant must prove it (s.11(2)). If conciliation fails: Labour Court, or CCMA arbitration where the employee earns below R269 600.90 a year (from 1 May 2026), alleges sexual harassment, or the parties agree (s.10(6)).	Referral to CCMA within 6 months of the act (EEA s.10(2))	AI08, AI24	EEA s.6, s.8, s.10, s.11 (LAW)
P3 Information Regulator complaint or assessment	IO, LC	Complaint, information notice or assessment by the Regulator	Assemble the AIIA, notices, operator agreements and logs; reply within the period the Regulator sets; comply with any enforcement notice.	As the Regulator directs	AI07, AI24	POPIA s.74, s.81, s.89–90, s.95, s.109 (LAW)
P4 Access or correction request	IO	Data subject asks what PI the AI holds or used, or asks for correction	Search prompts, outputs, logs and embeddings as well as source systems; respond; correct and notify recipients.	POPIA s.23 reasonable time; PAIA 30 days (s.56)	AI24	POPIA s.23–25 (LAW); PAIA s.50, s.56 (LAW)
P5 Security compromise	SEC, IO	Data leaked through prompts or outputs, compromised connector, account takeover	Phase 6 steps 6.2–6.4.	As soon as reasonably possible	AI23	POPIA s.22 (LAW)

Event	Who	Trigger	Organisational action	Deadline	Form	Authority
P6 IP or copyright claim	LC	Third party claims an output or training set infringes; client disputes ownership	Preserve records; stop use of the disputed output; notify the vendor under the indemnity; respond.	Per letter of demand (BP: 10 working days)	AI13	Copyright Act s.23–24 (LAW)
P7 Union consultation on monitoring or new technology	HR	Union or forum request, or planned new monitoring or AI work method	Disclose relevant information (s.16); consult the workplace forum where one exists (s.84(1)) or the union as the collective agreement requires; record agreement or reasons; adjust the deployment if needed.	Before roll-out (BP)	AI27	LRA s.16, s.84(1) (LAW); RICA s.6 (LAW)
P8 Staff misuse	HR, LM	Confidential or personal data put into an unapproved tool; deepfake; unverified AI output used; prohibited use	Contain (P5 if PI exposed); investigate; apply the Misconduct flow consistently with the rule as communicated (0.5).	Misconduct flow timelines	AI06	Code of Good Practice: Dismissal, 2025 (Code)
P9 Customer complaint about AI service	BO	Customer complains about a chatbot, AI-generated statement or AI-based decision	Human review; correct misleading statements; honour any representation made by the agent where the law requires; consider CPA and ECTA consequences.	2 and 20 working days (BP)	AI24	CPA s.41, s.48, s.69 (LAW); ECTA s.20 (LAW)
P10 Vendor or model change	AIGO	Vendor announces or makes a material change	Step 5.5; change control (4.8).	Before effect where possible	AI19	Contract (AI12)

Event	Who	Trigger	Organisational action	Deadline	Form	Authority
P11 Law or policy change	LC	Revised National AI Policy, Regulator guidance, sector rule or EU milestone	Assess impact on the register; update policy, tiers and notices; schedule re-assessments.	Within 60 days (BP)	AI29	BP
P12 Whistle-blower disclosure about AI	DO (PDA)	Employee discloses impropriety involving an AI system	Handle under the PDA flow; protect the discloser; feed findings back to AIGO.	PDA flow timelines	PDA flow forms	PDA 26 of 2000 (LAW)

Staff, user and affected-person obligations and conduct

The organisation can only rely on its AI controls if staff follow them. The table sets out what staff and users must do; the second table sets out rights that the organisation must not obstruct.

Obligation	When	Consequence if not met	Authority
Use only approved AI tools for work, and only for approved purposes	Always	Disciplinary action under the communicated rule	AI policy (AI01, AI06); Code of Good Practice: Dismissal, 2025 (Code)
Never enter personal, special, client-confidential or credential data into an unapproved tool	Always	Possible security compromise (s.22); disciplinary action	POPIA s.19, s.22
Verify AI output before relying on it or sending it outside the organisation	Every use	Inaccurate information; misleading representations; reputational and legal liability	POPIA s.16; CPA s.41

Obligation	When	Consequence if not met	Authority
Disclose material AI assistance in external work where policy requires	External content	Breach of policy or client contract	AI policy; client contracts
Do not create deepfakes, intimate or harmful images of real people	Always	Criminal liability; dismissal	Cybercrimes Act s.14–16
Exercise genuine human review where assigned as an overseer	High-risk decisions	Decision may be "solely automated" (s.71); unfair discrimination risk	POPIA s.71; EEA s.6
Report incidents, errors and suspected bias promptly	On discovery	Delayed containment and notification	POPIA s.22; AI policy
Complete AI literacy training	Induction and annually	Access withheld	AI policy (AI26)

Rights the organisation must not obstruct.

- The data subject's right to be notified of processing, to access and correct personal information, to object, and not to be subject to a solely automated decision except as s.71 allows (POPIA s.5, s.11(3), s.18, s.23–24, s.71).
- The right to complain to the Information Regulator (POPIA s.74) and to refer unfair discrimination disputes to the CCMA (EEA s.10).
- Employees' right to organise and to have their union consulted and informed (LRA s.16, s.84), and protection against victimisation for exercising these rights (LRA s.5).
- The right to make a protected disclosure about AI misuse (PDA).
- Consumers' rights to fair, honest and plain-language dealing (CPA s.22, s.40–41, s.48).

Hand-offs, RACI and interfaces register

RACI for the core activities

R = responsible; A = accountable; C = consulted; I = informed.

Activity	BOARD	AIC	AIGO	IO	HR	LC	SEC	DEV	BO
AI policy and tier scheme (0.1, 0.4)	A	R	R	C	C	C	C	I	I
AI register and discovery (0.3)	I	I	A	C	I	I	R	C	C
Intake and classification (1.1–1.7)	I	I	A	C	C	C	I	C	R
AIIA and PIA (2.1–2.4, 2.13)	I	C	A	R	C	C	C	C	C
Bias and EEA testing (2.5, 5.2)	I	C	A	C	R	C	I	R	C
Security and threat assessment (2.7)	I	I	A	C	I	I	R	R	I
Contracting (3A)	I	I	A	C	I	R	C	I	C
Build and evaluation (3B)	I	I	A	C	C	C	C	R	C
Go-live approval, high risk (4.2)	I	A	R	C	C	C	C	C	C
Notices and s.71 route (4.3–4.4)	I	I	A	R	R	C	I	C	C
Monitoring and re-assessment (5.1–5.7)	I	I	A	C	C	I	C	C	R
Incidents and s.22 notification (6.1–6.4)	I	I	A	R	I	C	R	C	C
Decommissioning (6.8–6.10)	I	A	R	C	I	C	R	C	R

Activity	BOARD	AIC	AIGO	IO	HR	LC	SEC	DEV	BO
Quarterly reporting (5.8)	I	C	R	C	C	C	C	I	I

Interfaces with other GBS flows and parties

Party or flow	Trigger	What is handed over	When	Step	Authority
GBS POPIA Compliance flow	PIA, operator agreement, s.22 compromise, data subject request	AIIA privacy modules; operator register entries; incident facts	As each arises	0.11, 2.2–2.4, 6.3, P4	POPIA
GBS Resourcing (Recruitment and Selection) flow	AI used in sourcing, screening, assessment or interview	Tier, bias results, candidate notice, s.71 review route	Before use in any vacancy	1.4, 2.5, 4.3–4.4	EEA s.6, s.8; POPIA s.71
GBS Performance Management flow	AI used to rate, rank or monitor performance	Oversight design; rating explanation; review route	Before the cycle starts	2.10, 4.4	POPIA s.71; LRA s.186(2)
GBS Misconduct flow	Staff misuse of AI; AI evidence in a disciplinary case	Incident record; acceptable-use acknowledgement; verified evidence only	On referral	P8	LRA
GBS Operational Requirements flow (+ Forms Pack)	AI deployment may lead to redundancies	Workforce impact assessment	Before any decision on dismissals	2.12	LRA s.189, s.189A
GBS PDA flow	Disclosure about AI impropriety	Disclosure; protection measures	Same day	P12	PDA
GBS Off-Boarding flow	Leaver with AI tool access	Access revocation list	Last working day	5.4	POPIA s.19
GBS Incapacity flow	AI used to infer health or performance capacity	Treat as high risk; special PI controls	Before use	1.4, 2.3	POPIA s.26, s.32; EEA s.6
GBS OHSA and COIDA flows	AI as a safety component; AI-related injury	Safety case; incident record	As arises	1.6, 6.1	OHSA; MHSA; COIDA

Party or flow	Trigger	What is handed over	When	Step	Authority
GBS CPA flow	Customer-facing AI statements, terms or complaints	Disclosures; complaint record	As arises	2.11, P9	CPA s.41, s.48
AI vendors and platforms	Due diligence, contract, change, incident, exit	Questionnaire; AI12 schedule; notices; deletion certificates	Per contract	3A, 5.5, 6.9	POPIA s.20–21
Clients (builders only)	Client AI project	Role allocation; system card; hand-over pack	Before client go-live	3B.5	POPIA s.20–21
Information Regulator	Compromise, complaint, prior authorisation	s.22 notice; responses; s.57 application	As required	2.3, 6.3, P3	POPIA
Trade union or workplace forum	Monitoring, new technology, policy	Information; consultation record	Before implementation	0.12, P7	LRA s.16, s.84
CCMA and Labour Court	Discrimination, unfair labour practice or dismissal dispute	AIIA, bias and decision records	Per referral	P2	EEA s.10; LRA s.191

Forms register

Thirty forms support the flow. None is a statutory form; where the law prescribes content (POPIA s.18 notices, s.21 operator terms, s.22 notifications through the Regulator's portal, s.71(3) measures), the GBS form is built to capture that content. Codes use the prefix **AI**; related POPIA forms sit in the GBS POPIA Compliance flow.

Form	Name	Used at	Owner	Statutory content captured
AI01	AI policy (board-approved)	0.1	AIGO	King V Principle 10 disclosure basis (STD)



Form	Name	Used at	Owner	Statutory content captured
AI02	AI Governance Committee terms of reference, role appointments and minutes	0.2, 1.8	AIGO	—
AI03	AI system register (inventory)	0.3, 0.9, 1.1, 1.4, 4.6, 5.4, 5.6	AIGO	POPIA s.17 processing records
AI04	Risk classification scheme and tier record	0.4, 1.3, 1.4	AIGO	—
AI05	AI use-case intake form and business case (incl. roles, foreign and sector scope)	1.1, 1.2, 1.5–1.7	BO	POPIA s.1 roles
AI06	Staff AI acceptable-use rules and acknowledgement	0.5, P8	HR	Rule known to employees (LRA Code)
AI07	AI impact assessment with integrated POPIA PIA	0.11, 2.1–2.4, 2.13, P3	AIGO, IO	POPIA Regulations reg. 4(1)(b); s.9–11, s.26–35, s.71
AI08	Bias and fairness test plan and report	2.5, 3B.3, 5.2, P2	HR	EEA s.8(a)–(c), s.11 evidence
AI09	Data sourcing and training-data record	2.6, 3B.2	DEV, IO	POPIA s.12, s.16
AI10	AI security and threat assessment	0.13, 2.7, 3B.3	SEC	POPIA s.19
AI11	Vendor AI due-diligence questionnaire and score	0.6, 3A.1	PROC	POPIA s.21
AI12	AI contract schedule and operator agreement addendum	0.6, 3A.2–3A.5, 3B.5–3B.6	LC	POPIA s.21, s.72
AI13	IP and copyright clearance memo	2.9, P6	LC	Copyright Act s.1, s.21
AI14	Human oversight design and decision-rights matrix	2.10	BO	POPIA s.71
AI15	Transparency notices (candidate, employee, customer, chatbot disclosure, content label)	2.11, 4.3	IO	POPIA s.18; EU AI Act art. 50 where in scope
AI16	s.71 representations and human review procedure and request form	2.4, 4.4, P1	IO	POPIA s.71(3)(a)–(b)
AI17	System card and technical documentation pack (incl. client hand-over)	0.13, 3B.1, 3B.4–3B.5	DEV	—

Form	Name	Used at	Owner	Statutory content captured
AI18	Go-live pack checklist and approval certificate	4.1, 4.2	AIGO	—
AI19	Change control record (model, version, instructions, data, purpose)	4.6, 4.8, 5.5, P10	AIGO, DEV	—
AI20	Monitoring plan and dashboard (performance, drift, bias)	3A.6, 4.7, 5.1, 5.2	BO	POPIA s.16
AI21	Human review and override log	0.9, 5.3, P1	BO	POPIA s.71 evidence
AI22	Periodic re-assessment record	5.7, 6.6	AIGO	POPIA Regulations reg. 4
AI23	AI incident report and register	0.8, 6.1–6.6, P5	AIGO	POPIA s.22(5) particulars
AI24	AI complaints and requests register	0.8, 6.7, P2–P4, P9	AIGO	POPIA s.23–25
AI25	Decommissioning checklist and deletion certificate	6.8–6.10	AIGO, SEC	POPIA s.14, s.21
AI26	AI literacy training record	0.7, 4.5	HR	—
AI27	Workforce impact and consultation record	0.12, 2.12, P7	HR	LRA s.16, s.84
AI28	Cross-border transfer assessment	2.8, 3A.4	IO	POPIA s.72, s.57(1)(d)
AI29	Legal and regulatory watch log	0.10, P11	LC	—
AI30	Quarterly AI governance report to the Board	5.8, 5.9, 6.11	AIGO	King V disclosure input

Timeline calendar and liability register

Life-cycle calendar (internal targets unless marked LAW)

When	Event	Source	Type
On receipt	Intake logged in the register	1.1	BP
Within 5 working days	Prohibited-use screen complete	1.3	BP
Within 10 working days	Tier assigned, assessment plan set	1.4–1.7	BP
Within 30 days of plan (high)	AIIA and residual-risk recommendation	2.13	BP
Before contract signature	Due diligence; operator and AI terms agreed	3A.1–3A.3	LAW (s.21 written contract) / BP
Before live personal data	Operator agreement signed; s.72 mechanism in place	3A.2, 3A.4	LAW
Before first live use	Notices issued; s.71 route live; users trained	4.3–4.5	LAW (s.18, s.71) / BP
First 30 days live	Hypercare and daily issue log	4.7	BP
Monthly / quarterly	Performance monitoring (high monthly, limited quarterly); bias monitoring quarterly	5.1–5.2	BP
Quarterly	Governance report to AIC and Board; access reviews	5.4, 5.8	BP
Every 12 months (high) / 24 months (limited)	Re-assessment	5.7	BP
Annually	AI policy review; staff acknowledgement; literacy refresh; internal audit	0.1, 0.5, 0.7, 5.9	BP
On s.71 request	Acknowledge in 2 working days; decide in 10	P1	BP



When	Event	Source	Type
On a security compromise	Notify Regulator and data subjects as soon as reasonably possible	6.3	LAW (s.22)
On a PAIA request	Decide within 30 days	P4	LAW (PAIA s.56)
Within 6 months of the act	Employee or applicant may refer an unfair discrimination dispute to the CCMA; if unresolved, Labour Court or (below the R269 600.90 threshold, sexual harassment, or by consent) CCMA arbitration	P2	LAW (EEA s.10(2), s.10(6))
Within 90 days	Unfair labour practice referral (e.g. AI-based promotion decision)	P2	LAW (LRA s.191(1)(b)(ii))
Within 30 days of dismissal or final decision	Unfair dismissal referral	P8	LAW (LRA s.191(1)(b)(i))

Key external dates

Date	Milestone	Label
2 February 2025	EU AI Act prohibitions (art. 5) and AI literacy (art. 4) apply	FOREIGN
1 April 2025	Information Regulator eServices portal mandatory for security-compromise reports	LAW (practice)
17 April 2025	Amended POPIA Regulations in force	LAW
1 June 2025	Joint Standard 2 of 2024 (cybersecurity and cyber resilience) commences for financial institutions	LAW (sector)
2 August 2025	EU AI Act GPAI obligations and penalties apply	FOREIGN
November 2025	FSCA and PA report on AI in the South African financial sector	POLICY
1 January 2026	King V applies to financial years starting on or after this date	STD
10 April 2026	Draft National AI Policy published (GN 3880, GG 54477)	DRAFT (withdrawn)



Date	Milestone	Label
26 April 2026	Draft National AI Policy withdrawn	POLICY
26 June 2026	Constitutional Court judgment on the Copyright Amendment Bill referral ([2026] ZACC 26); s.12D(1)–(5) invalid; Bill returns to Parliament before it can be signed	DRAFT
27 July 2026	Digital Omnibus on AI (Reg. (EU) 2026/1744) in force; amended art. 4 and new art. 4a apply	FOREIGN
2 August 2026	EU AI Act general application, incl. art. 50 transparency	FOREIGN
November 2026	Information Regulator members' second term ends	LAW (institutional)
2 December 2026	EU art. 50(2) marking for generative systems already on the market; new "nudifier" prohibition	FOREIGN
March 2027 (target)	Revised National AI Policy to Cabinet (moved from November 2026 by the Minister, September 2026); comment date to follow	POLICY
2 December 2027	EU AI Act Annex III high-risk duties (incl. employment and credit) apply	FOREIGN
2 August 2028	EU AI Act Annex I (product) high-risk duties apply	FOREIGN

Liability and offences register

Exposure	Consequence	Authority
POPIA administrative fine	Up to R10 million	POPIA s.109 (LAW)
POPIA offences	Fine or imprisonment up to 10 years for the most serious offences (e.g. obstruction, unlawful acts with account numbers, failure to comply with an enforcement notice); up to 12 months for others	POPIA s.100–107 (LAW)
POPIA civil claim	Damages for breach, including non-patrimonial loss, aggravated damages and costs, whether or not there is intent or negligence (limited defences)	POPIA s.99 (LAW)



Exposure	Consequence	Authority
Unfair discrimination (employees and applicants)	Compensation and damages; orders to stop the practice; burden on the employer	EEA s.6, s.11, s.50 (LAW)
Unfair labour practice or unfair dismissal	Reinstatement, compensation (up to 12 months' remuneration for dismissal; 24 for automatically unfair)	LRA s.193–194 (LAW)
Consumer harm	Administrative fine up to 10% of annual turnover or R1 million, whichever is greater; restitution	CPA s.112 (LAW)
Cybercrimes	Fine and/or imprisonment: up to 5 or 10 years for unlawful access and interference offences (s.2–7); up to 15 years for aggravated offences (s.11(1)); any sentence under CPA s.276 for cyber fraud, forgery and extortion (s.8–10); up to 3 years for harmful data messages and intimate images (s.14–16)	Cybercrimes Act s.19 (LAW)
Copyright infringement	Damages, interdict; criminal offences for knowing dealings in infringing copies	Copyright Act s.24, s.27 (LAW)
Interception without authority	Criminal offence	RICA s.2, s.49 (LAW)
EU AI Act (where in scope)	Up to EUR 35 million or 7% of worldwide turnover (prohibited practices); EUR 15 million or 3% (most other duties); EUR 7.5 million or 1% (misleading information)	EU AI Act art. 99 (FOREIGN)
Directors	Breach of fiduciary and care-and-skill duties where AI risk is not overseen	Companies Act 71 of 2008 s.76 (LAW)

Source review, drafting issues and sources

Verification notes (as at 19 October 2026)

- **National AI Policy.** Cabinet approved the draft for comment on 25 March 2026; published 10 April 2026 (GN 3880, GG 54477; comment deadline was 10 June 2026); withdrawn by Minister Malatsi on 26 April 2026 after fictitious citations were found (SAnews statement of that date). Advisory panel chaired by Prof Benjamin Rosman (Wits) announced at the budget vote on 12 May 2026. Target given in May 2026: revised draft to Cabinet November 2026, comment January 2027 (ITWeb, 26 May 2026); on 21 September 2026 the Minister said the draft would be ready for Cabinet by March 2027 (Daily Maverick), and the department has not announced a new comment date. TechCentral (29 July 2026) reports a "radical rethink" towards guidelines, sector strategies and existing regulators. The August 2024 National AI Policy Framework was a discussion document. **Status: no binding national AI policy and no AI Bill.** Re-check before adoption.
- **Information Regulator.** No AI-specific or s.71 guidance found (none as at March 2026 per ITLawCo; none found in searches on 19 October 2026; re-check before adoption). A guidance note on personal information impact assessments is planned for 2026/27. The Regulator's current members' term ends in November 2026.
- **EU AI Act.** Regulation (EU) 2024/1689 as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI): published 24 July 2026, in force 27 July 2026. Annex III high-risk deferred from 2 August 2026 to 2 December 2027; Annex I to 2 August 2028; art. 50 from 2 August 2026, with art. 50(2) grace to 2 December 2026 for systems already on the market; art. 4 recast as a duty to take measures to support AI literacy; new art. 4a on special-category data for bias detection; new prohibition of non-consensual intimate imagery ("nudification") from 2 December 2026. Confirmed against White & Case, Hunton and Cuatrecasas summaries of the Official Journal text (validation, 19 October 2026).
- **Copyright Amendment Bill.** The Constitutional Court delivered judgment on the President's referral on 26 June 2026 (*Ex parte President of the RSA: In re Constitutionality of the Copyright Amendment Bill and the Performers' Protection Amendment Bill* (CCT 306/24) [2026] ZACC 26): the fair-use and most exceptions were upheld, the educational exceptions in s.12D(1)–(5) were held unconstitutional, the equitable-remuneration provisions (ss 6A, 7A, 8A) were not decided, and the President may not sign



until Parliament cures the defect. It is not law. Neither the Bill nor the judgment addresses text-and-data mining or generative AI, so there is no statutory safe harbour for AI training; GBS should not rely on fair use for training until the Bill is enacted and tested.

- **EEA s.8(d).** Not in operation: *Association of Test Publishers of SA v President of the RSA* [2017] ZAGPPHC 144 (3 May 2017) declared Proclamation 50 of 2014 void to the extent it brought the amended s.8 into force; s.8 as at 31 July 2014 applies. No reported appeal found.
- **Cybercrimes Act s.54.** Most of the Act commenced on 1 December 2021; the s.54 reporting duty had not commenced at the last confirmed report (2024) and no later commencement proclamation was found on 19 October 2026 (open item; re-check).
- **Joint Standard 1 of 2023** (IT governance and risk management, financial institutions) is relevant to AI in financial services; it commenced on 15 November 2024.

Drafting issues and gaps worth raising

- **s.71 is narrow and untested.** It covers only decisions based *solely* on automated processing and gives no definition of "substantial degree". AI that heavily shapes but does not formally make a decision may fall outside it. The revised national policy or a Regulator guidance note should clarify meaningful human involvement.
- **EEA s.8 was written for psychometric tests.** Whether AI ranking and video analysis are "similar assessments" is unresolved by the courts. A Code of Good Practice on AI in employment under the EEA would help.
- **Computer-generated works.** Copyright Act s.1 attributes authorship to the person who made the arrangements, but the Act does not deal with AI training or with outputs that lack human creative input. The Copyright Amendment Bill does not resolve this.
- **No regulator of record for AI.** Until the revised policy assigns mandates, oversight will be spread across the Information Regulator, the Competition Commission, the National Consumer Commission, ICASA, the FSCA and PA and the Employment Equity enforcement system. Organisations should engage with sector regulators directly.
- **Liability for autonomous agents.** ECTA s.20 deals with electronic agents forming contracts but not with agents that take operational actions. Contract terms (AI12) must allocate this risk until the law does.

Validation record — v1.0 (19 October 2026)

Independent second-line validation on 19 October 2026 found 0 Critical, 2 Major, 10 Minor and 4 Improvement findings. All were implemented in this version. The key claims that were independently confirmed are the Draft National AI Policy dates (Cabinet 25 March 2026; GN 3880, GG 54477 on 10 April 2026; withdrawn 26 April 2026), Regulation (EU) 2026/1744 and its dates, and the Constitutional Court copyright judgment of 26 June 2026.

#	Finding (severity)	Where	Change made
1	Revised National AI Policy timeline out of date (Major)	§1 Legal status; 0.10; Key external dates; Verification notes	Cabinet target updated to March 2027 (Minister, 21 September 2026), replacing November 2026; January 2027 comment date replaced with 'comment date to follow'. Open: re-check before adoption.
2	AIIA-lite omitted statutory special-PI and cross-border tests (Major)	Phase 2 intro; 1.7; tier table	2.3 and 2.8 now apply at every tier whenever triggered (POPIA s.26–35, s.57, s.72).
3	Panel announcement date and withdrawal-date hedge (Minor)	Legal status; Verification notes	Panel announced 12 May 2026 (not 26 May); withdrawal confirmed as 26 April 2026 (SAnews); hedge removed.
4	Test Publishers outcome misdescribed (Minor)	Interpretation point 3; Verification notes	Explained that Proclamation 50 of 2014 was declared void, so s.8(d) is not in operation (3 May 2017). Open: no reported appeal found.
5	Cybercrimes Act penalties imprecise (Minor)	Liability register	s.19 penalty bands set out; '(verify)' removed.
6	Case citations unverified (Minor)	Interpretation point 7; Sources	Full citations added for Parker, Mavundla and Northbound; '(verify)' removed. Open: Northbound neutral citation not confirmed on SAFLII.
7	Code and CL labels missing; Dismissal Code labelled LAW (Minor)	§1 Labels; 0.5; P8; staff table; Sources	Code and CL labels added; Dismissal Code relabelled Code; cases labelled CL; meta status line updated.
8	AI03 cross-references incomplete (Minor)	Forms register	0.9 and 1.4 added.
9	Role DO undefined (Minor)	Roles used; P12	DO (designated PDA officer) defined.
10	s.71(3)(b) logic information limited to 'on request' (Minor)	4.4	Logic information now given with the decision notice, with more detail on request.
11	EEA s.11 burden paraphrase (Minor)	P2	Wording aligned to s.11(1) and s.11(2).



#	Finding (severity)	Where	Change made
12	Joint Standard 1 of 2023 commencement unresolved (Minor)	1.6; Verification notes; Sources	Commencement 15 November 2024 added; PA/FSCA report dated 24 November 2025.
13	EEA dispute routing after conciliation missing (Improvement)	P2; calendar	s.10(6) routing added, with BCEA threshold R269 600.90 (from 1 May 2026).
14	CPA consumer threshold missing (Improvement)	3A.3	R2 million juristic-person threshold added.
15	ConCourt copyright citation and AI point (Improvement)	2.9; Key dates; Verification notes; Sources	[2026] ZACC 26 (CCT 306/24) cited; ss 6A/7A/8A undecided; no TDM or AI-training safe harbour noted.
16	Workforce consultation basis unclear (Improvement)	0.12; P7	s.84(1) (workplace forum), s.16 disclosure, collective agreements and s.189 hand-off distinguished.
—	Open items	Verification notes	Information Regulator AI / s.71 guidance (none found); Cybercrimes Act s.54 commencement (not found); re-check both, and the AI policy timeline, before adoption. Version kept at v1.0.

Sources

- Constitution of the Republic of South Africa, 1996 s.9, s.14 (LAW).
- Protection of Personal Information Act 4 of 2013 s.1, s.5, s.8–25, s.26–35, s.55–58, s.71–72, s.74, s.99–109; POPIA Regulations, 2018 as amended (in force 17 April 2025) (LAW). Golegal, "New amendments to POPIA Regulations" (https://www.golegal.co.za/amendments-popia-regulations/); Werksmans, "Code Red to Code Regulated" (https://werksmans.com/code-red-to-code-regulated-south-africas-data-ai-and-cybersecurity-shift-in-2025-and-whats-to-come-in-2026/).
- Promotion of Access to Information Act 2 of 2000 s.50–51, s.56 (LAW).
- Employment Equity Act 55 of 1998 s.5, s.6, s.8, s.9, s.10, s.11, s.50 (LAW); *Association of Test Publishers of SA v President of the RSA* [2017] ZAGPPHC 144 (CL) (https://www1.saflii.org/za/cases/ZAGPPHC/2017/144.html).

- Labour Relations Act 66 of 1995 s.5, s.16, s.84, s.186, s.189, s.191, s.193–194, s.203 (LAW); Code of Good Practice: Dismissal, 2025 (GN 3470, GG 53294) (Code).
- Regulation of Interception of Communications and Provision of Communication-Related Information Act 70 of 2002 s.2, s.6 (LAW).
- Consumer Protection Act 68 of 2008 s.8–10, s.22, s.40–41, s.48, s.69, s.112 (LAW); Promotion of Equality and Prevention of Unfair Discrimination Act 4 of 2000 (LAW).
- Electronic Communications and Transactions Act 25 of 2002 s.20 (LAW); Cybercrimes Act 19 of 2020 s.2–10, s.14–16, s.19, s.54 (LAW).
- Copyright Act 98 of 1978 s.1, s.6–7, s.21, s.23–24, s.27 (LAW); Copyright Amendment Bill (DRAFT): *Ex parte President of the RSA: In re Constitutionality of the Copyright Amendment Bill* (CCT 306/24) [2026] ZACC 26 (CL); ENSafrica, "A decade in the making", July 2026 (https://www.ensafrica.com/news/detail/12103/a-decade-in-the-making-constitutional-court-r); Spoor and Fisher, "Copyright Amendment Bill: Constitutional Court clarifies the future of South Africa's copyright reform", July 2026 (https://spoor.com/copyright-amendment-bill-constitutional-court/).
- Companies Act 71 of 2008 s.76 (LAW); King V Code on Corporate Governance, IoDSA, 31 October 2025, Principle 10 (STD): Clyde and Co, "King V Code enhances principles regarding AI governance and cyber risks", November 2025 (https://www.clydeco.com/en/insights/2025/11/king-v-code-enhances-principles-regarding-ai-gover).
- Draft National Artificial Intelligence Policy, GN 3880, GG 54477, 10 April 2026 (DRAFT, withdrawn) (https://www.gov.za/sites/default/files/gcis_document/202604/54477gen3880.pdf); Cliffe Dekker Hofmeyr commentary (2026); Mail and Guardian, "Malatsi withdraws draft AI policy over fake citations", 27 April 2026; SAnews, "Minister announces withdrawal of draft AI Policy", 26 April 2026 (https://www.sanews.gov.za/south-africa/minister-announces-withdrawal-draft-ai-policy); ITWeb, "Malatsi appoints AI advisory panel", 12 May 2026 (https://www.itweb.co.za/article/malatsi-appoints-ai-advisory-panel/RgeVDvPRzbNMKJN3); ITWeb, "Government sets target for revised AI policy", 26 May 2026 (https://www.itweb.co.za/article/government-sets-target-for-revised-ai-policy/lwrKxv3Y2QyMmg1o); TechCentral, "Radical rethink for South Africa's national AI policy", 29 July 2026 (https://techcentral.co.za/radical-rethink-for-south-africas-national-ai-policy/284284/); Daily Maverick, "New draft AI policy will be ready by March, says Malatsi", 21 September 2026 (https://www.dailymaverick.co.za/article/2026-09-21-hallucination-free-hopefully-new-draft-ai-policy-will-be-ready-by-march-says-malatsi/) (POLICY).
- ITLawCo, "Information Regulator 2026/27 Annual Performance Plan" (https://itlawco.com/information-regulator-2026-27-annual-performance-plan/) (secondary).



- Prudential Authority and FSCA, *Artificial Intelligence in the South African Financial Sector*, November 2025 (POLICY); Baker McKenzie alert, December 2025 (https://www.bakermckenzie.com/en/insight/publications/alerts/2025/12/south-africa-regulators-assess-ai-in-finance); Joint Standard 1 of 2023 (commenced 15 November 2024) and Joint Standard 2 of 2024 (commenced 1 June 2025) (LAW, sector).
- ISO/IEC 42001:2023 (AI management systems); ISO/IEC 23894:2023 (AI risk management); ISO/IEC 42005:2025 (AI system impact assessment); ISO/IEC 42006:2025 (certification bodies); ISO/IEC 27001:2022 (STD).
- NIST AI Risk Management Framework 1.0 (January 2023) and Generative AI Profile NIST AI 600-1 (July 2024); OWASP Top 10 for LLM Applications; OECD Recommendation on AI (2019, updated May 2024); African Union Continental AI Strategy (July 2024) (STD / POLICY).
- Regulation (EU) 2024/1689 (AI Act) art. 2, 4, 5, 6, 26, 27, 50, 73, 86, 99; Regulation (EU) 2026/1744 (Digital Omnibus on AI), OJ 24 July 2026 (FOREIGN): nicfab.eu summary (https://www.nicfab.eu/en/posts/digital-omnibus-ai-official-journal/); Orrick, July 2026 (https://www.orrick.com/en/Insights/2026/07/EU-AI-Act-Update-Digital-Omnibus-Finalizes-8-Compliance-Changes); Gibson Dunn, 27 May 2026; White & Case, "EU AI Omnibus enters into force" (https://www.whitecase.com/insight-alert/eu-ai-omnibus-enters-force-amending-ai-act).
- *Parker v Forsyth NNO* (Johannesburg Regional Court, 29 June 2023); *Mavundla v MEC: Department of Co-operative Government and Traditional Affairs, KwaZulu-Natal* [2025] ZAKZPHC 2, 2025 (3) SA 534 (KZP); *Northbound Processing (Pty) Ltd v South African Diamond and Precious Metals Regulator* (Gauteng Division, Johannesburg, case 2025-072038, 30 June 2025) (CL).
- Statutes are cited from consolidated texts and general knowledge; verify section wording against the current consolidated Acts before adoption.

This flow is a working document for legal review, not legal advice.